SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad Mustafa Önler | Grup Gece-B | Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	PaketPro Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   - Bileşen Var mı?: Evet, Baykal APHS Abkant makinesinin CNC kontrol ünitesinde ve PLC firmware altyapısında "PaketPro Component X / PLC firmware kütüphanesi v2.4" muadili olan CNC/PLC kontrol kütüphanesi kullanılmaktadır.
   - Etkileniyor mu?: Evet, yayınlanan zafiyet bildirimi doğrudan v2.4 sürümünü hedeflemektedir.
   - Ulaşılabilir mi?: Evet, makinenin uzak bakım modülü ve fabrika ağı arayüzleri üzerinden dışarıdan ağ erişimine açık olması nedeniyle zafiyet uzaktan sömürülebilir (ulaşılabilirdir).

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır, üretimi derhal durdurmayız. Fabrikanın anlık operasyonel kayıp ve maliyet yaşamaması için, öncelikle zafiyetin sömürülme vektörünün ağ seviyesinde (firewall veya izolasyonla) kapatılıp kapatılamayacağına bakılır. Planlı bir bakım penceresi oluşturulana kadar geçici telafi edici önlemler devreye sokulur; acil duruş yalnızca aktif bir siber saldırı tespit edildiğinde uygulanır.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test mi?

   Asla doğrudan canlı üretim ortamına uygulanmaz. Yama, fabrikadaki aktif makineye kurulmadan önce üreticinin (Baykal) simülasyon ortamında veya fabrikadaki **Test/Laboratuvar Tezgâhında** eksiksiz olarak test edilir. Büküm eksenlerinin (X, Y, Z) toleranslarının ve PLC döngü sürelerinin kararlılığı doğrulanmadan canlı sisteme geçilmez.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Evet, PLC firmware kütüphanesinin güncellenmesi emniyet sistemiyle olan dijital köprüyü etkileyebilir. Bunu anlamak için yama sonrasında Safety PLC ile Normal PLC arasındaki haberleşme bütünlüğü test edilir, SIL/PL standartlarına uygunluk testleri (Functional Safety Verification) yeniden koşturulur ve ışık bariyeri tepki süreleri hassas ölçüm cihazlarıyla doğrulanır.

5 Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

Yamanın hemen uygulanamadığı veya sistem kararsızlığı yarattığı durumlarda alınacak telafi edici önlemler şunlardır:

- CNC kontrol ünitesi ile dış ağ/ERP arasındaki bağlantı geçici olarak kesilir (Ağ izolasyonu).
- Uzak erişim portları kapatılır; yalnızca yerel mühendislik istasyonundan fiziksel kablo ile kontrollü erişime izin verilir.
- Güvenlik duvarı (Firewall) kuralları sıkılaştırılarak zafiyetli porta gelen anormal paketler engellenir.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.